

Penetration Test Report

Prepared for Noriga Payments API

ENGAGEMENT	NRX-26Q1	WINDOW	Feb 9, 2026 – Apr 17, 2026
VERSION	v1	ISSUED	May 6, 2026
LEAD	Rami Moreau	TEAM	Rami Moreau
CLASSIFICATION	Confidential — Restricted		

Document Control

Revision History

Version	Date	Author	Description
v1	May 6, 2026	Rami Moreau	Initial release

Confidentiality Notice

This document contains confidential and proprietary information belonging to the client and the assessing firm. It is intended solely for the use of the named recipient(s). Disclosure, copying, distribution, or use of the contents of this document by any person other than the intended recipient is strictly prohibited.

The findings, recommendations, and opinions expressed in this report reflect the state of the assessed systems at the time of testing only. The assessing firm accepts no liability for the use or misuse of information contained herein.

Distribution: This report is classified *Confidential — Restricted*. Retain securely and do not transmit over unencrypted channels. Evidence and raw data are retained for 90 days and then cryptographically shredded.

Contents

0. Document Control	2
0.1. Revision History	2
0.2. Confidentiality Notice	2
1. Executive Summary	4
1.1. Findings at a Glance	4
1.2. Project Scope	4
1.3. Key Security Strengths	4
1.4. Key Areas for Improvement	4
2. Strategic Recommendations	5
2.1. Immediate Actions (0–30 Days)	5
2.2. Short-Term Improvements (30–90 Days)	5
2.3. Long-Term Security Hardening	5
3. Technical Details	6
3.1. Technical Scope	6
3.2. Testing Details	6
3.3. Engagement Timeline	6
4. Detailed Findings	7
4.1. Critical Risk Findings	8
F-P2-001 Broken object level authorization on payment endpoints	9
4.2. High Risk Findings	10
F-P2-002 Hardcoded API key in mobile app binary	11
Appendix A — CVSS Severity Ratings	12
Appendix B — Tools and Techniques	13
Appendix C — Glossary	14

Executive Summary

The Noriga Payments API assessment identified two critical vulnerabilities in the identity plane, both reachable from the internal network. A critical unauthenticated admin endpoint permits JWT signing-key rotation by any network-adjacent caller, and a high-severity algorithm-confusion flaw allows forged session tokens. Both issues require immediate remediation.

ass

Findings at a Glance

All issues identified during the engagement are summarized in **Table 1**.

Critical	High	Medium	Low	Informational
1	1	0	0	0

Table 1. Total findings by severity.

Project Scope

The following assets were in scope for this engagement:

- `api.noriga.internal` REST API — v2 endpoints, mTLS ingress
- `iOS v4.8` Mobile Client — Signed build 4.8
- `Android v4.8` Mobile Client — Signed build 4.8

Key Security Strengths

The environment demonstrated baseline security controls. Standard authentication mechanisms and input validation were observed on primary endpoints.

Key Areas for Improvement

- **[CRITICAL] Broken object level authorization on payment endpoints** — Implement BOLA/IDOR protection by always verifying that the authenticated user owns the requested resource
- **[HIGH] Hardcoded API key in mobile app binary** — Remove hardcoded secrets. Use certificate pinning and runtime key fetching with proper authentication

Strategic Recommendations

Immediate Actions (0–30 Days)

The following critical and high-severity findings require immediate attention:

- **CRITICAL F-P2-001** — Broken object level authorization on payment endpoints: Implement BOLA/IDOR protection by always verifying that the authenticated user o
- **HIGH F-P2-002** — Hardcoded API key in mobile app binary: Remove hardcoded secrets. Use certificate pinning and runtime key fetching with

Short-Term Improvements (30–90 Days)

No medium-severity findings in this assessment period.

Long-Term Security Hardening

The following strategic initiatives are recommended to strengthen the overall security programme:

- Implement a continuous vulnerability management programme with quarterly assessments.
- Establish a formal secure development lifecycle (SDLC) with security gates at design, code review, and deployment stages.
- Deploy a security information and event management (SIEM) solution for real-time threat detection.
- Conduct annual penetration tests against all internet-facing assets and internal network segments.

Technical Details

Technical Scope

The following assets were evaluated during this engagement:

Asset / URL	Type	Notes
api.noriga.internal	REST API	v2 endpoints, mTLS ingress
iOS v4.8	Mobile Client	Signed build 4.8
Android v4.8	Mobile Client	Signed build 4.8

Testing Methodology

The engagement followed the PTES execution phases mapped to OWASP WSTG v4.2 controls, combining authenticated and unauthenticated test runs across the full assessment window.

#	Activity	Primary Tooling
01	Reconnaissance	OSINT, DNS enumeration, asset discovery, Shodan
02	Threat Modelling	STRIDE analysis against service map
03	Vulnerability Analysis	Burp Suite Pro, Semgrep, Nuclei, manual testing
04	Exploitation	Controlled PoC — scoped to confirm impact only
05	Post-Exploitation	Read-only confirmation within agreed rules of engagement
06	Reporting	CVSS 3.1 scoring, CWE/OWASP mapping

Engagement Timeline

Milestone	Date / Period
Assessment Start	Feb 9, 2026
Assessment End	Apr 17, 2026
Report Issued	May 6, 2026
Retest Window	90 days from report issue

Rules of Engagement — No destructive testing, no customer PII handling, and no testing of out-of-scope third-party processors. Testing was conducted during agreed windows only.

Attack Narrative

App as s

Detailed Findings

All 2 identified findings are enumerated below, ordered by severity. Full technical details follow on subsequent pages.

ID	Severity	Title	Component	CVSS
F-P2-001	CRITICAL	Broken object level authorization on payment endpoints	—	8.1
F-P2-002	HIGH	Hardcoded API key in mobile app binary	—	7.5

Refer to Appendix A for CVSS severity rating definitions. Each finding on the following pages includes full technical details, reproduction steps, impact analysis, and remediation guidance.

Critical Risk Findings

CRITICAL

1 finding

Avg CVSS: 8.1

Critical findings represent direct, immediate threats exploitable with low effort. These require emergency remediation.

ID	Title	CVSS	Page
F-P2-001	Broken object level authorization on payment endpoints	8.1	9

FINDING F-P2-001

Broken object level authorization on payment endpoints

SEVERITY	CRITICAL
CVSS V3.1	8.1 AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N
CWE	CWE-639
OWASP	A01:2021
AFFECTED	api.noriga.internal/v2/payments

Description

Description

Payment API endpoints lack proper authorization checks at the object level. Authenticated users can access and modify payment records belonging to other accounts. a

Impact

Unauthorized access to financial records. Potential fund manipulation across all customer accounts.

Recommendations

Implement BOLA/IDOR protection by always verifying that the authenticated user owns the requested resource.

Technical Details

1. Create a payment and note its ID
2. Change your authentication token to another account
3. Access /v2/payments/{id} with the original payment ID
4. Observe full access to the other account's payment data

High Risk Findings

HIGH

1 finding

Avg CVSS: 7.5

High-severity findings pose significant risk to system integrity, confidentiality, or availability.
Remediate within 30 days.

ID	Title	CVSS	Page
F-P2-002	Hardcoded API key in mobile app binary	7.5	11

FINDING F-P2-002

Hardcoded API key in mobile app binary

SEVERITY	HIGH
CVSS V3.1	7.5 CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
CWE	CWE-798
OWASP	A02:2021
AFFECTED	iOS v4.8

Description

Description

Reverse engineering the mobile app binary reveals hardcoded API keys used to authenticate with the backend.

Affected Scope

- iOS v4.8
- Android v4.8

Impact

Unauthenticated access to backend APIs. Key cannot be easily rotated without app update.

Recommendations

Remove hardcoded secrets. Use certificate pinning and runtime key fetching with proper authentication.

Technical Details

1. Download the app APK/IPA
2. Decompile using jadx/frida
3. Search for API key patterns
4. Use extracted key to make unauthenticated API calls

Appendix A — CVSS Severity Ratings

Severity is assigned per finding using the *Common Vulnerability Scoring System v3.1*. Each finding records both the numerical score and vector string, allowing re-derivation against custom environmental context.

Severity	CVSS Range	Definition
CRITICAL	9.0 – 10.0	Direct, immediate threat. Exploitable by an unauthenticated attacker with low effort. Remediate immediately.
HIGH	7.0 – 8.9	Significant threat to sensitive systems or data, or a meaningful component of an attack chain. Remediate within 30 days.
MEDIUM	4.0 – 6.9	Threat requiring non-trivial preconditions but materially weakening posture. Remediate within 90 days.
LOW	0.1 – 3.9	Minor exposure with limited impact in isolation. Address as part of regular hygiene within 180 days.
INFORMATIONAL	0.0	Observation worth noting for hardening or hygiene. No immediate risk.

Note — CVSS scores reflect the *base score* only. Temporal and environmental modifiers are noted where relevant. Clients are encouraged to apply their own environmental vector to adjust scores to their specific context.

Appendix B — Tools and Techniques

The following tools and techniques were employed during the assessment. All tools were used in accordance with the agreed rules of engagement.

Tool / Technique	Category	Purpose
Burp Suite Professional	Web Proxy	HTTP interception, active scanning, session analysis
Nuclei	Scanner	Template-based vulnerability detection across web surfaces
Nmap / Naabu	Network Scanner	Port discovery, service version detection, OS fingerprinting
ffuf / Feroxbuster	Fuzzing	Directory enumeration, parameter fuzzing, wordlist attacks
Semgrep	SAST	Static analysis for common vulnerability patterns in source code
SQLMap	Exploitation	Automated SQL injection detection and exploitation
Amass / Subfinder	OSINT / Recon	Subdomain enumeration and asset discovery
JWT Tool	Token Analysis	JWT signature algorithm confusion and secret brute-forcing
Hashcat	Password Cracking	Offline hash cracking with GPU acceleration
Manual Testing	Methodology	Logic flaws, business process abuse, authentication bypass

Appendix C — Glossary

Key terms used throughout this report are defined below.

Term	Definition
Attack Surface	The set of all points at which an attacker can enter or extract data from a system.
Authentication Bypass	A vulnerability allowing access to protected resources without valid credentials.
CVSS	Common Vulnerability Scoring System — a standardised framework for rating vulnerability severity.
CWE	Common Weakness Enumeration — a community-developed list of software and hardware weakness types.
IDOR	Insecure Direct Object Reference — direct access to objects (records, files) using user-controlled input.
Lateral Movement	Techniques used by attackers to progressively move through a network after initial compromise.
OWASP	Open Worldwide Application Security Project — provides freely available security guidance and tools.
Penetration Test	Authorised simulated cyberattack against a computer system to evaluate security weaknesses.
PoC	Proof of Concept — a demonstration that a vulnerability exists and can be exploited.
PTES	Penetration Testing Execution Standard — a common methodology framework for penetration tests.
Remediation	The process of fixing or mitigating a discovered security vulnerability.
SQL Injection	Insertion of malicious SQL code into a query via user-supplied input fields.
STRIDE	A threat modelling framework covering Spoofing, Tampering, Repudiation, Info Disclosure, DoS, Elevation.
XSS	Cross-Site Scripting — injection of malicious scripts into web pages viewed by other users.